Risk Management Implementation

Program Plan · Framework Implementation & Gap Analysis · Risk Register · Continuous Monitoring

Turns the HVMC risk work of Weeks 9–11 into a running, monitored program for the next 12 months

Project Name	Healthcare IAM Operations Simulation
Organization	Horizon Valley Medical Center (HVMC)
Rubric	Risk Management Implementation (Semester 4, Week 11)
Deliverables	This report · **HVMC_Risk_Register_v2.xlsx** · **monitoring/** (continuous_monitor.py, kri_monitor.py, change_detector.py, test_change_detector.py, snapshots, logs)
Prepared By	Sabitha S Karanavar
Report Date	October 14, 2026

Rubric Cross-Reference

Rubric requirement	Section	Evidence
Complete program plan with realistic timelines, resource allocation and phase-based deployment	1	4 phases over 14 months with objectives, deliverables and exit criteria; 10 milestones; time allocation per person with hours; capacity check; budget per phase
Chosen framework implemented with documented customization	2.1–2.2	NIST RMF with ISO 31000 principles (COSO-compatible reporting); 10 documented customizations with rationale
Gap analysis	2.3	16 elements (RMF steps, ISO 31000 framework, CSF 2.0 functions) scored current vs target maturity, with evidence and closing actions
Integration procedures	2.4	8 procedures (change, access, joiner-mover-leaver, vendor, new systems, incidents, budget, HIPAA) with triggers, steps, owners and bypass detection
Comprehensive risk register with historical tracking	3 + Excel	Register v2: 27 fields per risk across all methods; append-only history (60 events); monthly snapshots; KRI, change and run logs
Continuous monitoring with automated indicators, threshold alerting and environmental change detection	4 + code	15 automated KRIs; Red/High alerting via exit codes; snapshot-diff change detection with severity rules (8 tests passing); CISA KEV threat-feed check; run history

> **Status today:** Phase 0 is complete. The live monitoring baseline shows **6 Red / 9 Amber / 0 Green** KRIs and a 12-resource environment snapshot. The second run detected no environmental changes and no new known-exploited CVEs for HVMC's software. Phase 1 starts October 19, 2026.

1. Risk Management Program Plan

1.1 Program charter

Purpose	Identify, evaluate, treat and continuously monitor information-security risk to HVMC's patients, ePHI and operations, as required by HIPAA §164.308(a)(1)
Scope	Azure subscription (HVMC-CloudSecurity-RG), Entra ID tenant (30 workforce identities, 10 RBAC groups), clinical and business systems, the Samba AD domain controller (from Phase 2), LIS/Pharmacy migration
Owner / sponsor	Denise Coleman (Security & Risk Lead) / Executive Risk Committee
Success measures	0 High risks by Dec 13, 2026 · ≥ 90% KRIs Green · all 8 integration procedures in use by Mar 31, 2027 · target maturity reached and external assessment passed by Sep 30, 2027

1.2 Phase-based deployment strategy

Each phase ends with exit criteria that must be met before the next begins. That way the organization first reduces its largest exposures, then builds routine, and only then invests in assurance and optimization.

Phase	Objective	Key deliverables	Exit criteria
P0 · Establish Aug 17, 2026 – Oct 18, 2026 **Complete**	Stand up the framework, governance and baseline	• NIST RMF + ISO 31000 framework and governance (Risk Management Fundamentals) • 16-risk register, ALE model, CIS checklist (Assessment) • Weighted scoring, BIA, exposure register (Evaluation) • 16-treatment mitigation plan (Mitigation Planning) • Board pack, dashboard, KPI framework (Communication)	Board briefing pack ready; baseline KRIs and snapshot captured
P1 · Remediate & instrument Oct 19, 2026 – Dec 13, 2026 **Starting**	Close the High risks and switch on continuous monitoring	• Board approval of plan and budget (Oct 21) • 16 mitigation treatments (C01–C14, T01, A01) • Daily continuous_monitor.py run scheduled • Azure Monitor alert rules + Log Analytics (C01) • Monthly KPI review starts (Nov 30)	0 High risks; ≥ 13 of 15 KRIs Green; all treatments verified
P2 · Operationalize Dec 14, 2026 – Mar 31, 2027 **Planned**	Make risk management routine and integrated with operations	• Integration procedures IP-1 to IP-8 live (change, access, JML, vendor, new systems, incidents, budget, HIPAA) • Samba AD domain controller brought into scope: categorize, mirror 30 identities, add DC KRIs • RMF Categorize→Authorize for LIS and Pharmacy migration • First quarterly cycle: control tests, residual re-score, Q4 board update (Jan) • Breach tabletop exercise with Privacy Officer	All 8 procedures used at least once; first quarterly cycle complete; DC monitored
P3 · Mature & assure Apr 01, 2027 – Sep 30, 2027 **Planned**	Prove effectiveness and raise maturity	• Independent assessment by external auditor (3rd line) • Monitoring moved to Azure Automation runbook (managed identity) • CSF 2.0 tier targets reached; annual framework review and re-authorization • Annual HIPAA risk analysis refresh from the register	Audit finds no High gaps; target maturity reached; framework v2.0 approved

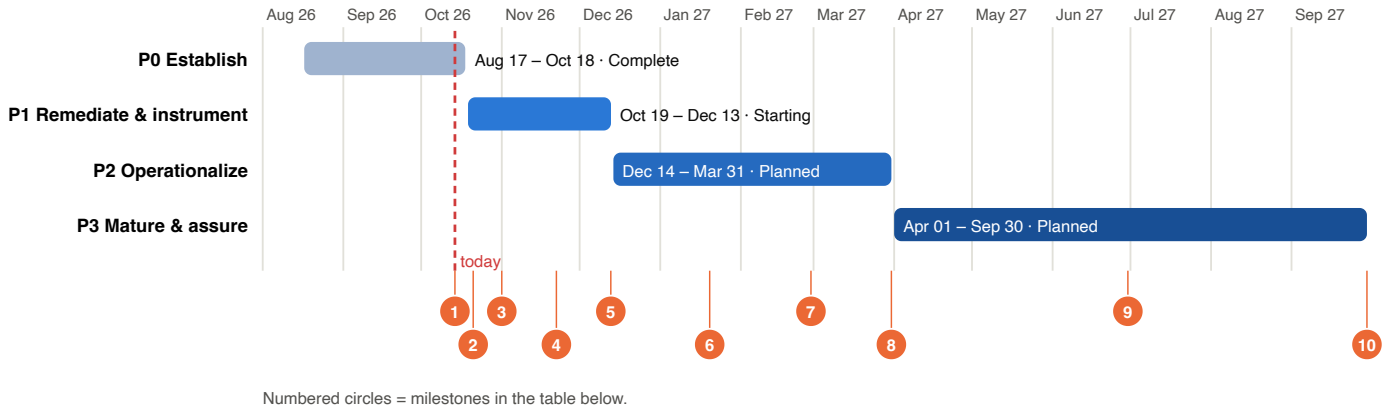


Figure 1 — Program timeline with milestones (red line = today).

#	Date	Milestone	Phase
1	Oct 14, 2026	Baseline KRIs and environment snapshot captured	P0
2	Oct 21, 2026	Board approves program, budget and insurance	P1
3	Nov 01, 2026	Phase 1 quick wins: 3 Red KRIs cleared	P1
4	Nov 22, 2026	Logging, alerts and recoverable EHR storage live	P1
5	Dec 13, 2026	Mitigation plan complete; residual risks accepted	P1
6	Jan 20, 2027	Q4 board update; first quarterly control tests	P2
7	Feb 28, 2027	Domain controller in scope and monitored	P2
8	Mar 31, 2027	LIS/Pharmacy migration authorized under RMF	P2
9	Jun 30, 2027	External assessment complete	P3
10	Sep 30, 2027	Annual review; framework v2.0 approved	P3

1.3 Resource allocation

Time is given as a share of a 40-hour week, converted to hours per phase (P1 = 8 weeks, P2 = 15, P3 = 26).

Role / person	P1	P2	P3	Responsibilities
Program sponsor Executive Risk Committee	2% 6 h	2% 12 h	2% 21 h	Approvals, budget, acceptance of residual risk
Security & Risk Lead Denise Coleman	30% 96 h	25% 150 h	20% 208 h	Program owner; register; monthly/quarterly reviews
RMF Program Lead Sabitha S Karanavar	50% 160 h	40% 240 h	30% 312 h	Framework, integration procedures, IAM controls, monitoring code
Security Officer Anthony Ruiz	40% 128 h	40% 240 h	30% 312 h	Daily monitoring triage, KRI log, checklist re-runs
Systems Administrator Fatima Ali	25% 80 h	15% 90 h	10% 104 h	Implements technical controls; DC hardening
IT Manager Kevin O'Brien	10% 32 h	10% 60 h	5% 52 h	Change management, contractor, IT risk owner
Finance Manager Brian Adeyemi	3% 10 h	2% 12 h	2% 21 h	Budget tracking, insurance
HR Manager Daniel Osei	3% 10 h	3% 18 h	2% 21 h	Sanction policy, training, JML records
System owners (×4) Sarah Chen, Elena Petrova, David Patel, Grace Nguyen	3% 10 h	5% 30 h	3% 31 h	Risk acceptance, access reviews, BIA updates

Why this is realistic: no one is allocated above 50%. The heaviest load is on the RMF Program Lead and the Security Officer in Phase 1, and both fall to 30% by Phase 3 as automation takes over daily monitoring. Phase 1 matches the hours already estimated in the mitigation plan. Phases are timed to avoid the December holiday period for go-lives: Phase 1 finishes Dec 13, and Phase 2 work in December is planning only.

1.4 Budget by phase

Phase	Internal hours	Internal labour (@ $75/h)	External / licences	Items
P1 (8 wks)	531 h	$39,840	$54,054	Licences & insurance (from mitigation plan, annual run-rate) $39,579; Legal review of BAA $1,500; mitigation one-time costs $12,975
P2 (15 wks)	852 h	$63,900	$300	Breach tabletop facilitation (internal) $0; Azure Monitor / Log Analytics growth $300
P3 (26 wks)	1,082 h	$81,120	$8,560	External risk assessment (auditor) $8,000; Azure Automation runbook $60; Training refresh $500
Program total				**$247,774** including internal time (cash outlay is the external column)

1.5 Program risks and dependencies

Program risk / dependency	Mitigation
Board approval delayed past Oct 21	Phase 1 quick wins (C02–C04, C08, C13, C14) cost under $3,000 and can proceed under existing IT budget
Key-person dependency on the RMF Program Lead (also the only Global Admin)	C04 adds a second admin in week 1; procedures and code are documented in the repository
Domain controller not yet operational (Samba AD service not running)	DC onboarding is scheduled for Phase 2; P1 does not depend on it
Entra ID P1/P2 licences required for C04, C07 and sign-in log export	Procured in Phase 1 week 1; C07 scheduled last in P1 to allow lead time
Monitoring runs from a workstation until Azure Automation (P3)	Daily schedule on an always-on host; a missed run shows as a gap in monitoring_log.jsonl and is checked weekly

2. Framework Implementation

2.1 Chosen framework

HVMC implements the **NIST Risk Management Framework (SP 800-37 Rev. 2)** as its operating process, guided by **ISO 31000:2018** principles and framework components. Outputs are kept **COSO ERM-compatible**, so cyber risk can roll up into enterprise risk reporting. RMF was chosen because HIPAA guidance (NIST SP 800-66 Rev. 2) maps directly to it, and its system-by-system structure matches HVMC's one-group-per-application access model.

2.2 Documented customization

Element	Standard expectation	HVMC customization	Rationale
RMF Prepare	Organization-wide risk strategy, roles, risk tolerance	Risk appetite set by the Board; Three Lines governance with named tenant users; risk tolerance expressed as score bands + critical-factor floor	Small organization: one Security & Risk Lead plays the senior-agency-official role
RMF Categorize	FIPS 199 impact levels per system	FIPS 199 plus a patient-safety override (any risk of patient harm = High integrity/availability) and BIA tiers (MTD-based)	HIPAA and clinical safety matter more than federal mission impact
RMF Select	SP 800-53 baseline, then tailor	Controls selected from NIST CSF 2.0 subcategories and ISO/IEC 27001:2022 Annex A, with SP 800-53 IDs for traceability	Full 800-53 baselines (300+ controls) are disproportionate for a 30-person hospital; CSF/ISO align with HIPAA and insurer questionnaires
RMF Implement	Implement and document controls	Controls implemented in Azure/Entra via change tickets; evidence = CLI output captured by the monitoring scripts	Automated evidence reduces documentation effort
RMF Assess	Independent control assessment (SP 800-53A)	Monthly automated checks + quarterly owner tests; independent external assessment annually (P3)	No internal audit function yet; external assessor provides independence
RMF Authorize	Authorizing Official issues ATO	Executive Risk Committee authorizes; conditional 90-day authorization when High residual risks remain	No federal AO; the Committee holds the decision rights defined in governance
RMF Monitor	Continuous monitoring strategy (SP 800-137)	Daily KRIs + environmental change detection + threat-feed check; results drive register updates	Automation makes daily monitoring feasible without a SOC
ISO 31000 Risk criteria	Organization defines how risk is evaluated	Four weighted factors (AHP: Operational 36%, Compliance 33%, Financial 19%, Reputation 12%)	Captures patient-care and HIPAA consequences that a single impact score hides
ISO 31000 Integration	Risk management integrated into all activities	Eight integration procedures (IP-1 to IP-8) embed risk checks in change, access, JML, vendor, projects, incidents, budget and HIPAA analysis	Turns the framework from a document into routine practice
COSO ERM (alignment)	Enterprise-wide view of risk and performance	Cyber register rolls up to enterprise risk via the Executive Risk Committee; ALE expressed in financial terms the CFO uses	COSO is not adopted as the main framework, but outputs are compatible with enterprise reporting

2.3 Gap analysis

Each element is scored on a 1–5 maturity scale (1 = Initial / ad hoc; 2 = Documented; 3 = Implemented & repeatable; 4 = Measured & monitored; 5 = Optimized), using evidence gathered in Weeks 9–11 and the live monitoring baseline.

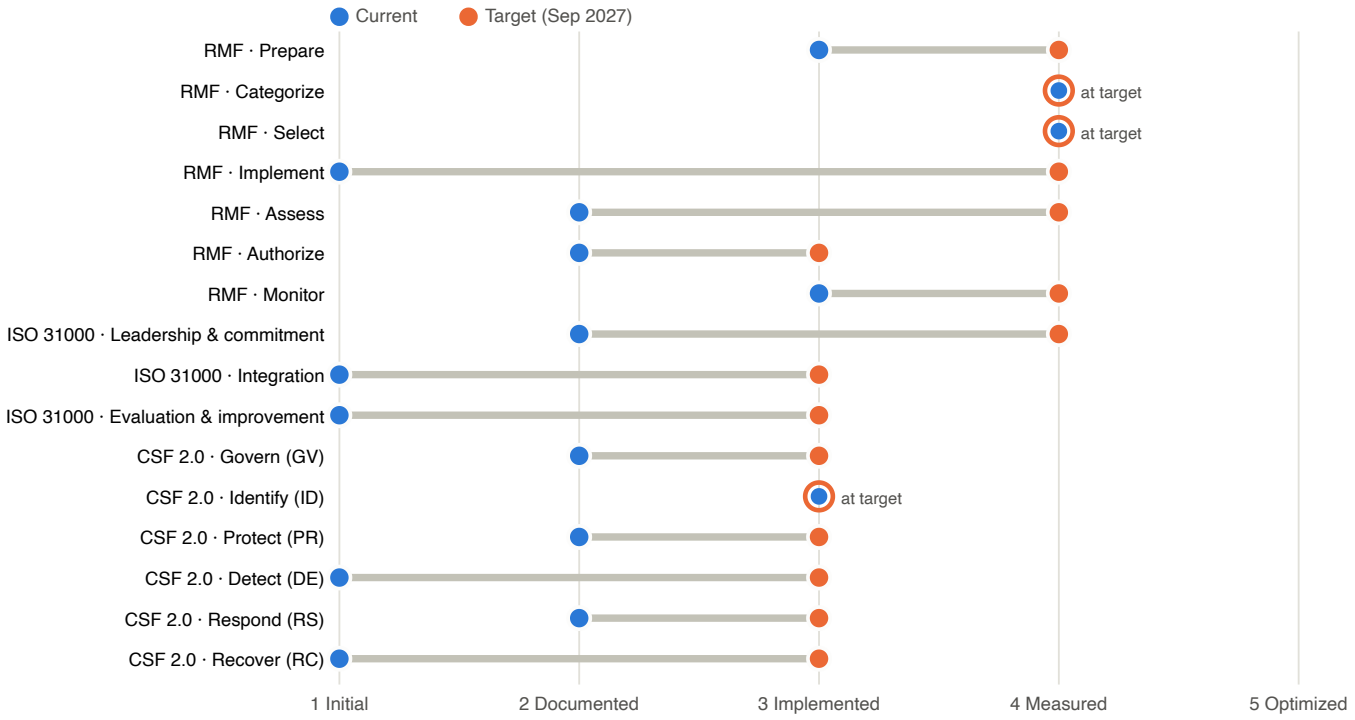


Figure 2 — Current vs target maturity.

Area	Element	Now	Target	Gap	Evidence (current state)	Closing action	Phase
RMF	**Prepare**	3	4	1	Governance, appetite and roles documented; Privacy Officer vacant; single Global Admin	Designate Privacy Officer (C11); second admin (C04)	P1
RMF	**Categorize**	4	4	0	10 systems categorized (FIPS 199) + BIA tiers	Add Samba DC and migrated LIS/Pharmacy	P2
RMF	**Select**	4	4	0	16 treatments mapped to CSF 2.0 / ISO 27001	Re-select at each new system	P2
RMF	**Implement**	1	4	3	0 of 16 treatments implemented; 6 Red KRIs live	Execute mitigation plan	P1
RMF	**Assess**	2	4	2	Automated checklist and KRIs exist; no control tests yet; no independent assessment	Quarterly control tests; external assessment	P2–P3
RMF	**Authorize**	2	3	1	Conditional authorization proposed, not yet signed	Committee signs EHR authorization after P1	P1
RMF	**Monitor**	3	4	1	Daily KRI + change detection scripts working; not yet scheduled; no Log Analytics	Schedule runs; deploy Log Analytics; Azure Automation	P1–P3
ISO 31000	**Leadership & commitment**	2	4	2	Board briefing prepared; approval pending	Board resolutions Oct 21; quarterly updates	P1
ISO 31000	**Integration**	1	3	2	Procedures designed, not yet used	Launch IP-1 to IP-8	P2
ISO 31000	**Evaluation & improvement**	1	3	2	KPI framework designed; no review cycle completed	Monthly KPI reviews; annual framework review	P2–P3
CSF 2.0	**Govern (GV)**	2	3	1	Policies and roles defined; supply-chain BAA missing	C11, C12, board cadence	P1
CSF 2.0	**Identify (ID)**	3	3	0	Asset inventory, BIA, register, threat feed check	Keep current via change detection	P2
CSF 2.0	**Protect (PR)**	2	3	1	MFA on; storage public; network not sealed; no CA	C02–C05, C07, C08	P1

Area	Element	Now	Target	Gap	Evidence (current state)	Closing action	Phase
CSF 2.0	**Detect (DE)**	1	3	2	No logs exported, no alert rules	C01, C06, scheduled monitoring	P1
CSF 2.0	**Respond (RS)**	2	3	1	IR playbook exists; untested; no Privacy Officer	Tabletop; C11	P2
CSF 2.0	**Recover (RC)**	1	3	2	Versioning off; restore never tested	C05 restore drills	P1–P2

Largest gaps (two or more levels): RMF Implement, RMF Assess, ISO 31000 Leadership & commitment, ISO 31000 Integration, ISO 31000 Evaluation & improvement, CSF 2.0 Detect (DE), CSF 2.0 Recover (RC). They share one cause: controls and routines are *designed* but not yet *operating*. Phase 1 (Implement, Detect, Recover) and Phase 2 (Integration, Evaluation) are aimed at exactly these.

2.4 Integration procedures

Integration makes risk management part of everyday decisions rather than a separate exercise (ISO 31000 §5.3). Each procedure has a trigger, steps, an owner and an output. The monitoring system also detects when a procedure was bypassed, for example an NSG change with no ticket.

Procedure	Trigger	Steps	Owner	Output	Bypass detection
IP-1 Change management	Any change to Azure resources, NSGs, storage or public IPs	Ticket with risk impact field → Security review if NSG/storage/public IP → approve → implement → evidence attached	Kevin O'Brien	Approved ticket; register updated if risk changes	change_detector flags changes with no matching ticket (weekly reconciliation)
IP-2 Access governance (privileged)	Directory role, Owner/Contributor assignment, tenant policy change	Request → Security & Risk Lead approval → PIM time-bound elevation → quarterly review	Denise Coleman	Approval record; PIM log	change_detector: new Global Admin = Critical, Owner = High
IP-3 Joiner-mover-leaver (JML)	HR onboarding, transfer or termination; contractor start/end	HR record → account created in AD (Samba DC) and Entra with same identity → group by role (RBAC matrix) → quarterly owner review → disable within 24 h of leave	Sabitha S Karanavar	Mirrored identity in DC and Entra; access review sign-off	change_detector: new users and group-membership changes reconciled with HR list
IP-4 Vendor & BAA onboarding	New vendor/contractor handling ePHI or with system access	Security questionnaire → BAA with indemnity → account with end date → listed in register if risk	Kevin O'Brien	Signed BAA; vendor risk entry	KRI K14 / user list: accounts without end date
IP-5 New system or migration (RMF)	New application, LIS/Pharmacy migration, domain controller in scope	RMF Categorize (FIPS 199 + BIA) → Select controls → Implement → Assess → Committee authorizes → add KRIs	Sabitha S Karanavar	Authorization decision; new KRIs; register entries	change_detector: new resources = Medium, triggers categorization
IP-6 Incident → risk feedback	Any security incident or near miss	Close incident → lessons learned → re-score linked risks → update controls/KRIs within 10 days	Anthony Ruiz	Register History entry; updated KRIs	Monthly check: incidents with no register update
IP-7 Budget & strategic planning	Annual budget cycle; major strategy change	Register ALE and treatment costs feed budget; Committee prioritizes by weighted score and ROSI	Brian Adeyemi	Funded treatment list	KPI G2 (ALE) trend reviewed quarterly
IP-8 Annual HIPAA risk analysis	Annually, or on major change (§164.308(a)(1)(ii)(A))	Export register + BIA + HIPAA matrix → refresh threats/vulns → re-score → board report	Denise Coleman	Dated HIPAA risk analysis	Review calendar in KPI Tracker

IP-3 implements the board requirement that the same 30 identities exist on the Samba AD domain controller and in Entra ID, with one HR record driving both. The change detector reconciles Entra users and group memberships against that list.

3. Comprehensive Risk Register with Historical Tracking

HVMC_Risk_Register_v2.xlsx consolidates every view of each risk produced across the program into one source of truth.

Sheet	Contents	Tracking feature
Register	16 risks × 27 fields: asset, threat, vulnerability, owner; 5×5 L/I and score; weighted F/O/C/R, weighted impact and score (formulas); strategy; treatments; live KRIs; target residual; status; dates; ALE	Formulas re-rate on any change; status drop-down; next-review date = last review + 30 days
History	60 events: Sept 8 scan findings → Oct 13 register creation and re-scores → Oct 14 method change to weighted scoring, treatment assignments and monitoring baseline	Append-only audit trail (who, when, old → new, why)
Monthly Snapshots	Counts by rating, total score, ALE and KRI status per period; actuals and plan targets	Trend: 2 Critical + 9 High (5×5, Oct 13) → 5 High (weighted, Oct 14) → target 0 High (Dec 13)
KRI Log	Every automated KRI value with status	Appended each run
Change Detection Log	Baseline and each detected change, with ticket reconciliation	Evidence for IP-1 to IP-3
Monitoring Runs	One row per continuous-monitoring run	Shows missed runs and alert history

3.1 Register governance

- **Owner:** Denise Coleman; **maintainer:** Anthony Ruiz. Risk owners update their own rows; only the maintainer edits scores.
- **Update triggers:** monitoring alerts, integration procedures (IP-1 to IP-8), incidents, quarterly re-scoring and the annual HIPAA analysis.
- **Retention:** history kept 6 years (HIPAA §164.316(b)(2)) in version-controlled storage (GitHub repository).
- **Version control:** the workbook is committed after each monthly review, so every past state can be recovered.

4. Continuous Monitoring System

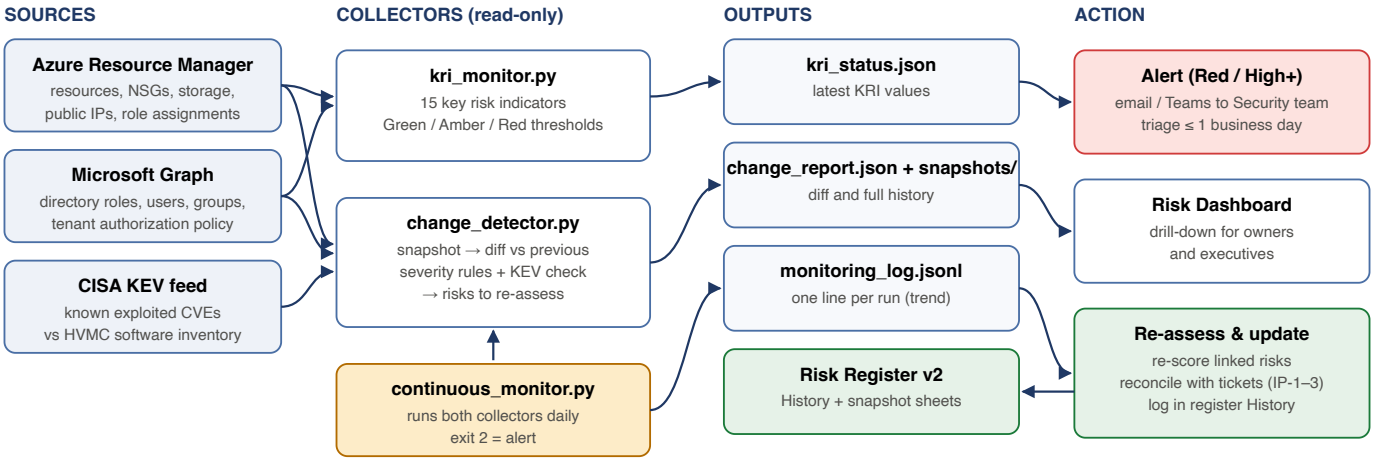


Figure 3 — Continuous monitoring architecture as implemented.

4.1 Automated indicators and threshold alerting

`kri_monitor.py` evaluates 15 KRIs (storage exposure, versioning, soft-delete, Data-tier deny rule, Global Admin count, log export, alert rules, flow logs, Defender, security contacts, tenant app and guest settings, test accounts, resource locks). Each KRI has an explicit Green/Amber/Red threshold. **Any Red raises an alert**: the script exits with code 2, which the scheduler turns into a notification to the Security team, with triage due within 1 business day.

4.2 Environmental change detection

`change_detector.py` captures a read-only snapshot of the environment (12 resources, 3 nsg rules, 2 role assignments, 1 directory roles, 32 users, 10 group members, 6 storage security, 3 public ips, 6 tenant policy) and compares it with the previous snapshot. Every difference is classified, linked to the risks to re-assess, and tied to the integration procedure that should have authorized it:

Change detected	Severity	Re-assess	Expected authorization
New Global Administrator	Critical	R04	IP-2
New internet-facing inbound allow rule (source * / Internet)	High	R03	IP-1
New public IP address	High	R03, R10	IP-1
Owner / Contributor / User Access Administrator assignment	High	R04, R07	IP-2
EHR storage setting moves away from secure value	High	R02, R05	IP-1
EHR storage setting moves to secure value	Info	R02, R05	(good news — verify KRI turns Green)
Any other NSG change; new resource; tenant policy change; group membership change	Medium	R01–R03, R08, R13, R15	IP-1 / IP-2 / IP-3 / IP-5
New or removed user; removed resource	Low	R06, R07	IP-3

External change detection: with `--threat-feed`, the detector downloads the CISA Known Exploited Vulnerabilities catalogue and flags entries added in the last 30 days for products in HVMC's inventory (OpenSSH, Apache HTTP Server, Azure, Entra, Samba). On the live run the catalogue held 1741 entries, with 0 new matches for HVMC.

4.3 Verification

Test	Result
Baseline run against live tenant	Snapshot 2026-10-14T18-45-21Z.json captured: 12 resources, 3 nsg rules, 2 role assignments, 1 directory roles, 32 users, 10 group members, 6 storage security, 3 public ips, 6 tenant policy
Second live run	**No changes detected (correct: nothing changed)**
8 unit tests with simulated changes (test_change_detector.py)	**All passed: new Global Admin → Critical; internet RDP rule, new public IP, Owner assignment, weakened TLS → High; hardened storage → Info; new user → Low; group change → Medium; every change names risks and a procedure**
Full cycle (continuous_monitor.py)	Logged run: KRIs 6 Red / 9 Amber / 0 Green; 0 changes; 0 KEV hits; **alert = true** (Red KRIs open)

4.4 Operating the system

```
# daily 07:00 on an always-on host (Phase 1–2); moves to an Azure Automation runbook with a managed identity in
Phase 3
0 7 * * *  cd /opt/hvmc-risk/monitoring && python3 continuous_monitor.py || notify-security-team   # exit 2 = alert
```

- **Daily:** Anthony Ruiz triages alerts; each detected change is reconciled with its ticket or HR record. An unmatched change is treated as a potential incident.
- **Weekly:** check monitoring_log.jsonl for missed runs; review Amber trends.
- **Monthly:** results feed the KPI review and the register snapshot; the workbook is committed to version control.
- **On change of scope** (domain controller, LIS/Pharmacy migration): add KRIs and snapshot categories through IP-5. For the DC, planned KRIs are Kerberos AES-only, SMB signing/encryption and an identity mirror check against Entra.

5. Conclusion

HVMC's risk management is now a program rather than a set of documents. A four-phase, 14-month plan with realistic time allocations and a phased budget takes it from the completed baseline to an independently assessed, mature state. NIST RMF is implemented with ten documented customizations for a small healthcare organization. A 16-element gap analysis shows the remaining work is mainly *operating* what has been designed, and eight integration procedures embed risk decisions in daily operations. The comprehensive register keeps a complete, append-only history. The continuous monitoring system collects 15 KRIs, alerts on thresholds, detects environmental and threat-landscape changes, and has been tested against the live tenant.

References

- NIST SP 800-37 Rev. 2 (RMF); NIST SP 800-137 (Information Security Continuous Monitoring); NIST SP 800-66 Rev. 2 (HIPAA).
- ISO 31000:2018 *Risk management — Guidelines*; COSO *Enterprise Risk Management — Integrating with Strategy and Performance* (2017).
- NIST CSF 2.0 (2024); ISO/IEC 27001:2022.
- CISA Known Exploited Vulnerabilities Catalog (cisa.gov/known-exploited-vulnerabilities-catalog).
- 45 CFR §164.308(a)(1), §164.316(b)(2).
- HVMC risk program: Fundamentals, Assessment Techniques, Evaluation Methods, Mitigation Planning and Risk Communication deliverables.

Appendix A — Running the monitoring system

```
cd monitoring
python3 continuous_monitor.py          # KRIs + change detection + threat feed; appends monitoring_log.jsonl; exit
2 = alert
python3 kri_monitor.py                 # KRIs only  -> kri_status.json
python3 change_detector.py --threat-feed  # snapshot + diff -> change_report.json, snapshots/
python3 test_change_detector.py        # 8 unit tests using simulated changes (no Azure access needed)
# requires: Azure CLI signed in with Reader + Directory Reader (read-only)
```

Prepared for: Sabitha — Healthcare IAM Operations Home Lab | Risk Management rubric — Risk Management Implementation (Semester 4, Week 11)